

BÁO CÁO DỰ ÁN

Hệ thống SecureChat

NGUYỄN VŨ THÀNH

Thanh14704@gmail.com

Lĩnh Vực: Kỹ Sư Phần Mềm: Lập Trình Hệ Thống

Mentor hướng dẫn: Lê Thành Thân

Đơn vị: Viettel Cypher Security

Chương trình: Viettel Digital Talent

HÀ NỘI, 6/2026

TÓM TẮT NỘI DUNG DỰ ÁN

Dự án trình bày việc thiết kế và phát triển hệ thống SecureChat - một giải pháp truyền thông thời gian thực (Real-time Communication) theo mô hình Client-Server. Hệ thống được xây dựng hoàn toàn bằng ngôn ngữ C++ với mục tiêu đáp ứng đồng thời hai yêu cầu : Hiệu năng xử lý đồng thời cao ở mức cao (High Concurrency) và Bảo Mật thông tin đa lớp.

Ở phía Máy chủ (Server), kiến trúc hệ thống được thiết kế dựa trên mô hình điều khiển sự kiện bất đồng bộ (Event-Driven) sử dụng *epoll*, kết hợp cùng mô hình Thread Pool. Điều này cho phép Server xử lý bài toán C10K một cách tối ưu, không bị thất nút cổ chai tại các luồng I/O mạng. Cơ sở dữ liệu SQLite được tích hợp cùng cơ chế Write-Ahead Logging (WAL) giúp đảm bảo tốc độ truy vấn thông tin người dùng và lịch sử hệ thống trong môi trường đa luồng.

Về mặt Giao thức và Bảo mật, hệ thống không sử dụng các giao thức văn bản truyền thống mà lựa chọn sử dụng giao thức truyền tải nhị phân tùy chỉnh (Custom Binary Protocol) với Header chứa mã kiểm lỗi CRC32. Quá trình bảo mật áp dụng mô hình mã hóa lai (Hybrid Crypto): sử dụng RSA-2048 để trao đổi khóa phiên một cách an toàn ở bước bắt tay (Handshake), sau đó toàn bộ payload giao tiếp được mã hóa và xác thực tính nguyên vẹn bằng chuẩn AES-256-GCM.

Ngoài ra, dự án tập trung nghiên cứu và cài đặt một dịch vụ an ninh mạng chủ động ngay trong nhân máy chủ, bao gồm: module Hệ thống phát hiện xâm nhập (Intrusion Detector - IDS) để phân tích hành vi độc hại, bộ định tuyến giới hạn tốc độ (Rate Limiter) chống lại các cuộc tấn công DoS/Spam dựa trên thuật toán Token-Bucket, và Nhật ký kiểm tra (Audit Logger) lưu vết các thao tác nhạy cảm. Phía Client cài đặt giao diện dòng lệnh (CLI) nhẹ, hỗ trợ đa dạng tính năng nghiệp vụ từ nhắn tin cá nhân, phòng chat nhóm, truyền tải tập tin, đến các tập lệnh của quản trị viên (Admin Commands).

Kết quả đạt được là một nền tảng giao tiếp tin cậy, hoạt động ổn định và đáp ứng các tiêu chuẩn bảo mật thực tế, có khả năng mở rộng và tích hợp thêm các dịch vụ khác trong tương lai.

MỤC LỤC

Danh sách hình vẽ	iii
Danh sách bảng	iv
CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI	1
1.1 Khảo sát hiện trạng	1
1.1.1 Đặt vấn đề	1
1.1.2 Mục tiêu và phạm vi của đề tài	2
1.2 Phân tích yêu cầu hệ thống	3
1.2.1 Yêu cầu chức năng	3
1.2.2 Yêu cầu phi chức năng	4
CHƯƠNG 2. NỀN TẢNG LÝ THUYẾT VÀ CÔNG NGHỆ SỬ DỤNG	6
2.1 Kiến trúc mạng và giao thức	6
2.1.1 Mô hình Client-Server	6
2.1.2 Giao thức TCP/IP	6
2.2 Công nghệ mã hóa và bảo mật	6
2.2.1 Mã hóa đối xứng AES	6
2.2.2 Mã hóa bất đối xứng RSA	6
2.2.3 Hàm băm SHA256 và xác thực HMAC	6
2.3 Công nghệ xử lý đồng thời và hiệu năng cao	6
2.3.1 I/O Multiplexing và mô hình epoll	6
2.3.2 Mô hình Thread Pool	6
2.4 Lý thuyết phòng thủ và an ninh mạng	6
2.4.1 Hệ thống phát hiện xâm nhập (IDS)	6
2.4.2 Thuật toán Rate Limiting (Token-Bucket)	6
2.5 Hệ thống lưu trữ và cơ sở dữ liệu	6
2.5.1 Cơ sở dữ liệu SQLite	6
2.5.2 Cơ chế Write-Ahead Logging (WAL)	6
2.6 Công cụ và Thư viện phát triển	6

CHƯƠNG 3. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ	7
HỆ THỐNG	7
3.1 Kiến trúc tổng thể hệ thống	8
3.1.1 Kiến trúc Server	8
3.1.2 Kiến trúc Client	8
3.2 Thiết kế giao thức giao tiếp	8
3.2.1 Cấu trúc gói tin	8
3.2.2 Luồng xử lý thông điệp	8
3.3 Thiết kế cơ chế bảo mật	8
3.3.1 Cơ chế trao đổi khóa (Key Exchange)	8
3.3.2 Xác thực chứng chỉ số	8
3.4 Thiết kế hệ sinh thái an ninh mạng chủ động	8
3.4.1 Hệ thống phát hiện xâm nhập (IDS)	8
3.4.2 Bộ định tuyến giới hạn tốc độ (Rate Limiter)	8
3.4.3 Nhật ký kiểm toán (Audit Logger)	8
3.5 Thiết kế cơ sở dữ liệu	8
3.5.1 Sơ đồ thực thể liên kết (ERD)	8
3.5.2 Quản lý người dùng và trạng thái	8
3.6 Thiết kế logic tính năng nghiệp vụ	8
3.6.1 Quản lý phòng Chat nhóm (Rooms)	8
3.6.2 Cơ chế truyền tải tập tin (File Transfer)	8
3.6.3 Các tập lệnh quản trị hệ thống (Admin Commands)	8
3.7 Triển khai và Đánh giá	8
3.7.1 Môi trường triển khai	8
3.7.2 Đánh giá kết quả đạt được	8
CHƯƠNG 4. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	9
4.1 Kết luận	9
4.2 Hướng phát triển	9

Danh sách hình vẽ

Danh sách bảng

DANH MỤC THUẬT NGỮ VÀ TỪ VIẾT TẮT

Từ viết tắt	Ý nghĩa
TCP	Transmission Control Protocol
TLS	Transport Layer Security
AES	Advanced Encryption Standard
RSA	Rivest-Shamir-Adleman

CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI

1.1 Khảo sát hiện trạng

1.1.1 Đặt vấn đề

Sự phát triển vượt bậc của hạ tầng mạng Internet và thiết bị di động đã gia tăng đáng kể nhu cầu giao tiếp trực tuyến. Trong bối cảnh đó, các ứng dụng truyền thông thời gian thực (Real-time Communication) đóng vai trò nền tảng trong việc duy trì luồng trao đổi thông tin liên tục và đa chiều. Thành phần cốt lõi của các hệ thống này là kiến trúc máy chủ (Chat Server) với năng lực xử lý cao, đảm nhiệm vai trò tiếp nhận, điều phối và định tuyến thông điệp song công (full-duplex) với độ trễ thấp giữa một số lượng lớn thiết bị máy khách (Client) phân tán.

Tuy nhiên, việc thiết kế và triển khai một kiến trúc mạng đáp ứng yêu cầu trên đối mặt với nhiều thách thức kỹ thuật phức tạp, trong đó trọng tâm là bài toán tối ưu hiệu năng. Khi hệ thống phải duy trì hàng chục nghìn kết nối đồng thời (bài toán C10K), mô hình cấp phát luồng theo kết nối (thread-per-client) truyền thống thường bộc lộ những hạn chế cố hữu, gây ra hiện tượng thắt cổ chai I/O mạng (Network I/O Bottleneck) và suy kiệt tài nguyên phần cứng. Thêm vào đó, việc sử dụng các giao thức dựa trên văn bản (Text-based Protocol) làm gia tăng chi phí phân tích cú pháp (parsing overhead) và hao phí băng thông. Những vấn đề này đặt ra yêu cầu cấp thiết trong việc xây dựng hệ thống dựa trên các mô hình I/O đa kênh tiên tiến (I/O Multiplexing), kết hợp cùng thiết kế cấu trúc gói tin nhị phân (Binary Protocol) nhằm giảm thiểu kích thước dữ liệu và tối ưu hóa triệt để độ trễ truyền tải.

Bên cạnh năng lực xử lý đồng thời, việc bảo mật luồng dữ liệu truyền tải là một yêu cầu kỹ thuật mang tính tiên quyết. Nhiều kiến trúc hệ thống hiện hành vẫn bộc lộ lỗ hổng trong cơ chế kiểm soát truy cập và bảo vệ kênh truyền, làm gia tăng nguy cơ đối mặt với các hình thức tấn công mạng như nghe lén (Eavesdropping), tấn công xen giữa (Man-in-the-Middle) hay cạn kiệt tài nguyên (DoS/Spam). Việc nghiên cứu và tích hợp các module phòng thủ chủ động - bao gồm mã hóa dữ liệu, hệ thống phát hiện xâm nhập (Intrusion Detection System - IDS) và cơ chế giới hạn lưu lượng (Rate Limiter) - là giải pháp thiết yếu để chuyển đổi một máy chủ truyền thông tiêu chuẩn thành một kiến trúc giao tiếp an toàn, khép kín và có độ tin cậy cao.

Xuất phát từ những thách thức kỹ thuật và nhu cầu thực tiễn nêu trên, việc nghiên cứu, thiết kế và phát triển một hệ thống “Secure Chat Server” hiệu năng cao là một

định hướng cấp thiết. Đề tài đòi hỏi việc kiểm soát toàn diện kiến trúc hệ thống, từ phần tối ưu hóa I/O mạng, định tuyến thông điệp Client-Server tốc độ cao, cho đến việc triển khai các cơ chế bảo mật chuyên sâu đa lớp. Hướng tiếp cận này không chỉ giải quyết trọn vẹn bài toán vận hành thực tế mà còn đóng góp giá trị học thuật cao trong lĩnh vực lập trình hệ thống và an toàn thông tin.

1.1.2 Mục tiêu và phạm vi của đề tài

Mục tiêu của đề tài

Đề tài hướng tới việc nghiên cứu, thiết kế và phát triển hoàn chỉnh một hệ thống máy chủ truyền thông (Secure Chat Server) hiệu năng cao, ứng dụng mô hình Client-Server với các mục tiêu cụ thể như sau:

- Tối ưu hóa hiệu năng xử lý đồng thời: Ứng dụng các công nghệ điều khiển sự kiện bất đồng bộ (I/O Multiplexing với *epoll*) và mô hình Thread Pool để giải quyết triệt để bài toán C10K, đảm bảo hệ thống có thể duy trì hàng chục nghìn kết nối mạng với độ trễ tối thiểu và không xảy ra hiện tượng thất cổ chai I/O.
- Thiết kế giao thức truyền tải tối ưu: Xây dựng một giao thức gói tin nhị phân tùy chỉnh (Custom Binary Protocol) nhằm loại bỏ chi phí phân tích cú pháp (parsing overhead) và tiết kiệm băng thông mạng so với các giao thức dựa trên văn bản thông thường.
- Tích hợp hệ sinh thái an ninh mạng đa lớp: Triển khai mô hình mã hóa lai (Hybrid Crypto) sử dụng RSA-2048 để trao đổi khóa và AES-256-GCM để mã hóa tải trọng (payload). Đồng thời, xây dựng các module bảo mật chủ động trực tiếp trong nhân máy chủ bao gồm: Hệ thống phát hiện xâm nhập (IDS), Cơ chế giới hạn lưu lượng (Rate Limiter sử dụng thuật toán Token-Bucket) và Hệ thống nhật ký kiểm toán (Audit Logger).
- Đảm bảo tính nhất quán dữ liệu: Sử dụng hệ quản trị cơ sở dữ liệu SQLite kết hợp với cơ chế Write-Ahead Logging (WAL) để đảm bảo an toàn dữ liệu và tối ưu tốc độ truy vấn trong môi trường đa luồng.

Phạm vi nghiên cứu

Trong khuôn khổ của đồ án, phạm vi nghiên cứu và triển khai được giới hạn ở các khía cạnh sau:

- Phạm vi kiến trúc hệ thống: Tập trung chuyên sâu vào việc xây dựng kiến trúc lõi của phần mềm Máy chủ (Server-side) bằng ngôn ngữ C++ hiện đại. Phần mềm Máy khách (Client-side) được phát triển dưới dạng giao diện dòng lệnh (CLI), đóng vai trò như một công cụ tương tác thực tế để kiểm chứng hiệu quả của các tính năng nghiệp vụ.
- Phạm vi tính năng nghiệp vụ Hệ thống: triển khai đầy đủ các tính năng giao tiếp cốt lõi bao gồm: Nhắn tin cá nhân (Direct Message), Nhắn tin và quản lý phòng trò chuyện nhóm (Rooms), Truyền tải tập tin (File Transfer) và các Tập lệnh quản trị viên (Admin Commands).
- Phạm vi đánh giá và kiểm định: Đề tài tập trung đo lường năng lực xử lý (benchmark) dưới điều kiện tải cao và mô phỏng các kịch bản tấn công mạng cơ bản (như DoS, quét cổng, giả mạo gói tin) nhằm kiểm chứng năng lực phòng thủ của các module an ninh. Đề tài không mở rộng nghiên cứu sang việc phát triển giao diện đồ họa người dùng (GUI) hay các nền tảng ứng dụng di động.

1.2 Phân tích yêu cầu hệ thống

1.2.1 Yêu cầu chức năng

Dựa trên mục tiêu xây dựng một nền tảng trò chuyện bảo mật toàn diện, hệ thống cần đáp ứng các nhóm yêu cầu chức năng cốt lõi sau:

- **Quản lý phiên kết nối và người dùng:** Hệ thống phải hỗ trợ người dùng kết nối (Connect), ngắt kết nối (Disconnect) và duy trì trạng thái hoạt động thông qua cơ chế nhịp tim (Ping/Pong). Hệ thống cũng cần cho phép người dùng tra cứu danh sách những tài khoản đang online và xem thông tin chi tiết (Whois) của một người dùng cụ thể.
- **Giao tiếp và Nhắn tin:**
 - *Nhắn tin cá nhân (Private Chat):* Cho phép hai người dùng trao đổi thông điệp trực tiếp với nhau một cách bảo mật.
 - *Nhắn tin nhóm (Room Chat):* Hỗ trợ tính năng tra cứu danh sách phòng (List Rooms), tạo phòng mới (Create Room), tham gia (Join), rời phòng (Leave) và gửi tin nhắn quảng bá (Broadcast) tới tất cả các thành viên trong phòng.

- **Truyền tải tệp tin (File Transfer):** Hệ thống cần tích hợp tính năng gửi và nhận tệp tin P2P hoặc thông qua server. Quá trình này bao gồm các bước kiểm soát chặt chẽ: gửi yêu cầu truyền tệp (File Request), chấp nhận/từ chối (Accept/Reject), và truyền dữ liệu theo từng khối (File Data) để không gây nghẽn luồng thông điệp chính.
- **Quản trị hệ thống (Admin Commands):** Cung cấp đặc quyền cho quản trị viên thực hiện các thao tác kiểm duyệt, quản lý cộng đồng như: kích xuất người dùng (Kick), cấm chat (Mute), cấm truy cập (Ban), thăng cấp quản trị (Promote) và gửi thông báo toàn hệ thống (System Broadcast).
- **Thiết lập bảo mật sơ khởi:** Chức năng tự động thực hiện bắt tay mật mã (Crypto Handshake) ngay khi có kết nối mới nhằm trao đổi khóa công khai và thiết lập kênh truyền mã hóa trước khi bất kỳ dữ liệu nghiệp vụ nào được phép lưu thông.

1.2.2 Yêu cầu phi chức năng

Bên cạnh các tính năng nghiệp vụ, hệ thống đặc biệt chú trọng vào các yêu cầu phi chức năng nhằm đảm bảo hiệu năng, độ tin cậy và an toàn thông tin tuyệt đối trong môi trường mạng thực tế:

- **Bảo mật và Toàn vẹn dữ liệu (Security & Integrity):**
 - Mọi thông điệp truyền tải trên mạng lưới phải được mã hóa bằng thuật toán chuẩn công nghiệp (AES) với khóa phiên (Session Key) được phân phối an toàn qua cơ chế mã hóa bất đối xứng (RSA).
 - Hệ thống phải chống lại được các hành vi đánh tráo, thay đổi nội dung gói tin thông qua việc sử dụng mã xác thực thông điệp (HMAC) kết hợp cùng hàm băm SHA256.
 - Tích hợp hệ thống ghi nhận nhật ký kiểm toán chống can thiệp (Tamper-evident Audit Logger) lưu trữ trên cơ sở dữ liệu SQLite, cho phép truy vết chính xác và hệ thống sẽ báo động nếu file log bị chỉnh sửa trái phép từ bên ngoài.
 - Có module Phát hiện xâm nhập (Intrusion Detector) để tự động nhận diện và ngắt kết nối các client có hành vi gửi gói tin dị thường, sai cấu trúc hoặc có dấu hiệu tấn công từ chối dịch vụ (DoS).

- **Hiệu năng và Khả năng mở rộng (Performance & Scalability):** Máy chủ phải được thiết kế theo kiến trúc hướng sự kiện (Event-driven) sử dụng vòng lặp bất đồng bộ (Event Loop) kết hợp với mô hình đa luồng (Thread Pool). Điều này đảm bảo luồng chính của hệ thống không bị nghẽn (non-blocking) bởi các thao tác I/O chậm chạp, đáp ứng khả năng xử lý hàng chục nghìn kết nối đồng thời (bài toán C10K) với độ trễ xử lý (Latency) ở mức thấp nhất.
- **Tính tin cậy và Khả năng chịu lỗi (Reliability & Fault Tolerance):** Máy chủ phải có cơ chế xử lý mượt mà các tình huống phân mảnh gói tin TCP (TCP Packet Fragmentation) hoặc dính gói. Nếu phía client đột ngột mất mạng, hệ thống phải tự động nhận diện thông qua cơ chế timeout của Ping/Pong và dọn dẹp tài nguyên (socket, session) để ngăn chặn hoàn toàn rò rỉ bộ nhớ (Memory Leak).

CHƯƠNG 2. NỀN TẢNG LÝ THUYẾT VÀ CÔNG NGHỆ SỬ DỤNG

2.1 Kiến trúc mạng và giao thức

2.1.1 Mô hình Client-Server

2.1.2 Giao thức TCP/IP

2.2 Công nghệ mã hóa và bảo mật

2.2.1 Mã hóa đối xứng AES

2.2.2 Mã hóa bất đối xứng RSA

2.2.3 Hàm băm SHA256 và xác thực HMAC

2.3 Công nghệ xử lý đồng thời và hiệu năng cao

2.3.1 I/O Multiplexing và mô hình epoll

2.3.2 Mô hình Thread Pool

2.4 Lý thuyết phòng thủ và an ninh mạng

2.4.1 Hệ thống phát hiện xâm nhập (IDS)

2.4.2 Thuật toán Rate Limiting (Token-Bucket)

2.5 Hệ thống lưu trữ và cơ sở dữ liệu

2.5.1 Cơ sở dữ liệu SQLite

2.5.2 Cơ chế Write-Ahead Logging (WAL)

2.6 Công cụ và Thư viện phát triển

CHƯƠNG 3. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

3.1 Kiến trúc tổng thể hệ thống

3.1.1 Kiến trúc Server

3.1.2 Kiến trúc Client

3.2 Thiết kế giao thức giao tiếp

3.2.1 Cấu trúc gói tin

3.2.2 Luồng xử lý thông điệp

3.3 Thiết kế cơ chế bảo mật

3.3.1 Cơ chế trao đổi khóa (Key Exchange)

3.3.2 Xác thực chứng chỉ số

3.4 Thiết kế hệ sinh thái an ninh mạng chủ động

3.4.1 Hệ thống phát hiện xâm nhập (IDS)

3.4.2 Bộ định tuyến giới hạn tốc độ (Rate Limiter)

3.4.3 Nhật ký kiểm toán (Audit Logger)

3.5 Thiết kế cơ sở dữ liệu

3.5.1 Sơ đồ thực thể liên kết (ERD)

3.5.2 Quản lý người dùng và trạng thái

3.6 Thiết kế logic tính năng nghiệp vụ

3.6.1 Quản lý phòng Chat nhóm (Rooms)

3.6.2 Cơ chế truyền tải tập tin (File Transfer)

3.6.3 Các tập lệnh quản trị hệ thống (Admin Commands)

CHƯƠNG 4. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

4.1 Kết luận

4.2 Hướng phát triển